# EduPulse SMT Ghana Data Protection Technical Brief

## Purpose

This document is a technical briefing for legal and compliance review. It maps the current EduPulse SMT technical controls and documentation to the practical data-protection issues most likely to matter under Ghana's Data Protection Act, 2012 (Act 843).

This is not formal legal advice. It is a technical-control summary for counsel.

## Business Name

**EduPulse SMT**

## Scope Of Data Processed

The platform processes data relating to:

1. Students
2. Parents and guardians
3. School staff and operators
4. Proprietors and school administrators
5. Billing and payment records
6. Security, authentication, and audit events

## Role Positioning: School vs Platform

The existing privacy documentation already points to an important legal distinction:

1. Each school is the primary controller of school-originated student and guardian data in its operational context
2. EduPulse SMT acts as the platform operator and processor/service provider for those schools in many processing activities

Counsel should review whether the contracts and data-processing language make this relationship explicit enough.

## Technical Controls Currently Evident

### 1. Access Control

The platform documents and code show:

1. Role-based access control
2. School/tenant isolation
3. Restricted access to sensitive finance and audit functions

This supports the basic data-protection principle that access should be limited to authorized users with legitimate operational roles.

### 2. Encryption In Transit

The policy and security documentation state TLS encryption in transit as a control expectation. This supports secure transmission of credentials, school data, and payment-related requests.

### 3. Application-Layer Encryption At Rest For Sensitive Fields

The codebase implements `EncryptedString` using Fernet-based encryption. Sensitive fields in models include parent contacts and saved bank data.

This is stronger than relying only on generic database storage because the application encrypts selected values before persistence.

### 4. Tamper-Evident Logging For Finance Records

Finance events are written into a ledger chain using HMAC-SHA256 with a dedicated ledger secret.

This helps support:

1. Integrity of payment evidence
2. Fraud detection
3. Forensic review
4. Regulator and audit defensibility

### 5. Webhook Authentication For Payment Events

Paystack webhook handling verifies the gateway signature using HMAC SHA-512 and the Paystack secret key.

This reduces the risk of unauthenticated fake payment callbacks entering the system.

### 6. Secrets Management And Production Hardening

The documented production posture expects secrets to be injected securely rather than hardcoded. The AWS deployment notes reference:

1. AWS Secrets Manager
2. Encrypted volumes
3. Encrypted backups using SSE-KMS
4. Private database exposure

### 7. Incident And Breach Handling

The compliance docs include an incident-response plan and breach-notification structure. The operations docs also include incident update templates. This supports regulator and school-facing response readiness.

### 8. Retention And Deletion Governance

The retention policy sets retention periods for academic, billing, audit, and security data, and defines a DSAR workflow with verification, SLAs, evidence records, and deletion/anonymization controls.

## Data Categories And Legal Sensitivity

The higher-sensitivity categories in practice are likely to include:

1. Student records and academic history
2. Parent and guardian contact details
3. School staff identity and access information
4. Saved bank and payment-routing details
5. Payment and audit records

These categories justify the use of encryption, role restriction, logging, and retention controls.

## DSAR And Rights Handling

The repo documentation already describes support for:

1. Access requests
2. Rectification
3. Deletion or erasure subject to legal obligations
4. Restriction or objection where applicable
5. Export or portability where feasible

The retention policy also describes:

1. Intake channels
2. Identity verification
3. Response SLAs
4. DSAR evidence records

Counsel should ensure the external-facing legal documents and internal execution procedures remain aligned on these response timelines and evidence expectations.

## Cross-Border And Cloud Considerations

The privacy documentation already acknowledges that data may be stored or processed outside Ghana with appropriate safeguards.

From a technical standpoint, the main cloud-related issues for counsel are:

1. Where production workloads and backups are hosted
2. Whether secrets and encrypted backups are controlled under strong IAM restrictions
3. Which service providers process personal data, including Paystack and cloud vendors
4. Whether the contractual chain with those providers is adequate for Ghana data-protection purposes

## Evidence Points In The Repository

The strongest evidence files for legal/compliance review are:

- `compliance/PRIVACY_POLICY.md`
- `compliance/DATA_RETENTION_POLICY.md`
- `compliance/INCIDENT_RESPONSE_PLAN.md`
- `compliance/INFORMATION_SECURITY_POLICY.md`
- `PRIVACY_POLICY.md`

- `SECURITY.md`
- `AUDIT_INTEGRITY_SYSTEM.md`
- `backend/security/crypto.py`
- `backend/api/models.py`
- `backend/routes.py`

## Likely Ghana Compliance Themes For Counsel

Counsel will likely want to examine:

1. Whether controller/processor roles are defined clearly enough in school contracts
2. Whether consent, authority, and school-side responsibility language are adequate for minors' data and guardian contact information
3. Whether breach-notification procedures are framed in a regulator-ready way
4. Whether cross-border storage and service-provider clauses are sufficiently disclosed
5. Whether retention, deletion, and export rights are contractually and operationally aligned

## Practical Risk Areas To Review

The technical posture is relatively strong, but counsel should still review these risk areas:

1. Placeholder legal fields still awaiting formal company registration details or address information
2. Whether all high-risk data flows have matching contractual language
3. Whether school-side user behavior could still cause improper data entry or disclosure despite platform controls
4. Whether internal roles and named owners are formalized in corporate documents, not only operating docs

## Short Position

EduPulse SMT already shows a serious technical-control posture for a school SaaS product in Ghana: role-based access, tenant isolation, selected field encryption, webhook authentication, tamper-evident finance logging, incident planning, and structured retention policy.

The main legal task is to make sure the contracts, policies, incorporation records, and regulator-facing positions correctly describe and support those technical realities.